GOVERNANÇA DE TECNOLOGIA DA INFORMAÇÃO



Izabelly Soares de Morais

Revisão técnica:

Jeferson Faleiro Leon
Graduado em Desenvolvimento de Sistemas
Especialista em Formação Pedagógica



M827g Morais, Izabelly Soares de.
Governança de tecnologia da informação [recurso eletrônico] / Izabelly Soares de Morais, Glauber Rogerio Barbieri Gonçalves; [revisão técnica: Jeferson Faleiro Leon]. – Porto Alegre: SAGAH, 2018.

ISBN 978-85-9502-343-7

1. Tecnologia da informação. I. Gonçalves, Glauber Rogerio Barbieri. II.Título.

CDU 004

Catalogação na publicação: Karin Lorien Menoncin CRB-10/2147

Regulamentações da governança em TI

Objetivos de aprendizagem

Ao final deste texto, você deve apresentar os seguintes aprendizados:

- Descrever os principais norteadores dos regulamentos existentes na governança de TI.
- Reconhecer as regulamentações de *compliance*.
- Analisar as implicações do *Sarbanes-Oxley Act*.

Introdução

Vivemos em uma sociedade em que temos diversos deveres e direitos perante as nossas ações e comportamentos, não é verdade? Dessa forma, no contexto corporativo e nas suas respectivas atividades de negócio existem também inúmeras leis e regras que regem a execução de tarefas. Nesse sentido, quando a governança de TI é aplicada, traz consigo outras novas regras e normas regulamentárias de suas funções.

Neste capítulo, estudaremos os principais marcos regulamentários da governança de TI. Além disso, você aprenderá sobre as principais leis que regem as ações da governança de TI dentro de um contexto corporativo.

Principais marcos regulatórios da governança de TI

Quando lidamos com qualquer tipo de processo ou atividade, devemos encarar também suas respectivas regras para uso. Isso significa que praticamente toda ação, hoje em dia, tem algum marco regulatório. O objetivo é delimitar o uso de recursos e a maneira como podem ser utilizados, bem como em que contextos podem ser aplicados.

Podemos visualizar o marco regulatório como um conjunto de normas que visam acompanhar o uso dos recursos. Nesse caso, os recursos tecnológicos.

Geralmente, eles trazem um norteamento quanto à maneira como algumas auditorias devem ser realizadas. Além disso, contribuem para a elaboração de novas metodologias, procedimentos e até mesmo manuais. Esses tutoriais trazem meios organizacionais e de execução das práticas de fiscalização que podem ser aplicadas em cada área, em que o objetivo principal é sempre garantir a qualidade dos serviços e produtos disponibilizados.

Devemos ter em mente que os recursos tecnológicos são utilizados em todos os contextos, não só no Brasil, mas também em outros países. Nos países mais desenvolvidos, principalmente, onde os recursos podem ser até mais avançados e de menor custo, sua aquisição é mais bem aceita dentro do contexto corporativo, tendo em vista que a adoção de algo novo nem sempre é bem-vinda por todos os empregados.

Os principais marcos regulatórios que norteiam o contexto da governança de TI são:

- Inicialmente, não podemos deixar de mencionar as regulamentações que regem as ações contra a corrupção nas empresas, as quais a relacionamos com a política de *compliance*.
- A lei *Sarbanes-Oxley,* a qual possui o objetivo de trazer a representatividade do mercado corporativo de capitais americanos (SARBANES; OXLEY, 2002). Nesse contexto, podemos incluir regulamentações criadas após a crise financeira de 1929. Falaremos, a seguir, um pouco mais sobre essa lei.
- Outra lei que também se enquadra aqui é, na verdade, o que chamamos de Acordo da Basileia II (BANCO DO BRASIL, 2004), que traz aspectos relacionados a riscos de crédito e riscos operacionais das empresas.

Podemos citar também acordos do Banco Central do Brasil (BACEN) que regem diretrizes sobre as empresas e suas estruturas de gerenciamento de risco, como a Resolução BACEN nº 3.380, de 29 de junho de 2006 (BANCO CENTRAL DO BRASIL, 2006).

Lembre-se de que a lista não se esgota por aqui! Os principais órgãos regulamentadores são a Agência Nacional de Telecomunicações (ANATEL), para empresas que possuem atividades nessa área de atuação, e o BACEN, que trata das instituições bancárias e financeiras.



Fique atento

O COSO (COMMITTEE OF SPONSORING ORGANIZATIONS OF THE TREADWAY COMMISSION), é um comitê criado em 1985 nos EUA para prevenir fraudes em demonstrações contábeis. Trata-se de uma organização sem fins lucrativos formada por representantes das principais associações de classes ligadas à área financeira. Dedica-se à melhoria nos relatórios financeiros, sobretudo pelo cumprimento de controles internos e pela aplicação da ética profissional. Atualmente, as recomendações do COSO são amplamente praticadas em todo o mundo, inclusive no Brasil (SANTOS; BARUQUE, 2010, p. 198).

Política de *compliance*

Diante das diversas possibilidades que uma empesa tem de se formar e se compor de serviços e produtos que serão disponibilizados para a sociedade e, enquanto isso, também será fonte de emprego e geração de renda, sejam por meio de lucros ou impostos, faz-se necessária a presença de instrumentos que regulamentem essas ações. Nesse contexto, estamos falando de uma política denominada *compliance*.

Mas o que isso quer dizer?

Conforme Ribeiro e Diniz (2015, p. 02), *compliance* é uma expressão que se volta para as ferramentas de concretização da missão, da visão e dos valores de uma empresa. Portanto, não se pode confundir *compliance* com o mero cumprimento de regras formais e informais, pois seu alcance é bem mais amplo. Ou seja, "[...] é um conjunto de regras, padrões, procedimentos éticos e legais, que, uma vez definido e implantado, será a linha mestra que orientará o comportamento da instituição no mercado em que atua, bem como a atitude dos seus funcionários" (CANDELORO; RIZZO; PINHO, 2012, p. 30).

Ainda sob o ponto de vista dos autores, *compliance* envolve questão estratégica e se aplica a todos os tipos de organização, visto que o mercado tende a exigir cada vez mais condutas legais e éticas para a consolidação de um novo comportamento por parte das empresas, as quais devem buscar lucratividade de forma sustentável, focando no desenvolvimento econômico e socioambiental para a condução dos seus negócios (RIBEIRO; DINIZ, 2015).

Observe que, para falarmos de governança em TI, também temos que abordar conceitos que norteiam o contexto dos negócios e suas condutas éticas e profissionais, pois é neste ambiente que a governança de TI é aplicada.

Então, qual seria o objetivo da implantação da política de *compliance* em uma corporação empresarial?

Podemos destacar:

- trazer a obrigatoriedade do cumprimento das leis vigentes não só no país, mas também das leis internacionais que condizem com as atividades desempenhadas pela empresa, sendo que essas regras também abrangem as leis internas da corporação;
- tomar precauções a respeito de solicitações judiciais;
- propiciar transparência para os processos da empresa;
- assegurar confidencialidade para dados de clientes e dos processos que são executados dentro do âmbito empresarial;
- evitar que haja divergências entre os interesses comuns dos clientes;
- impedir a criação de contextos falsos com o intuito de gerar lucro;
- prevenir o uso ilícito do dinheiro e até mesmo emprego de lucros indevidos e que não pertencem à organização.

Esses são apenas alguns dos pontos em que a política de *compliance* pode atuar no contexto corporativo. Todos eles sempre guiarão, para esse ambiente, métricas relacionadas a honestidade e transparência quanto às ações éticas perante os funcionários e as regras do negócio.

A implantação desse tipo de política requer a elaboração de um programa, o qual se refere a uma documentação que expõe todas as informações da empresa, como políticas adotadas, processos que estão sendo executados, projetos futuros e até os que já foram executados, entre outras. Esse relato deve conter basicamente toda a história da empresa, e não se trata de sua história de vida, mas de suas atividades. Não se pode esquecer que a ética sempre prevalecerá nesse contexto, então, deve ser inserida em um código de conduta adotado pela empresa.

Conforme Gonçalves (2012, p. 64), com a implantação da política de *compliance*, a empresa tende a orientar todas as suas ações para os objetivos definidos, utilizar os recursos de forma mais eficiente, visto que as decisões passam a ser mais econômicas, pois serão uniformes para casos similares; proteger-se contra as pressões das emergências, ter uniformidade e coerência em todos os seus atos e decisões, colaborando com a transparência dos processos. Além disso, o negócio busca facilitar a adaptação de novos empregados à cultura organizacional, disponibilizar mais tempo aos gestores para repensarem políticas e atuarem em questões estratégicas, e aumentar e aperfeiçoar o conhecimento da organização por todos os seus atores.

Vale salientar que, com a aplicação e uso da política de *compliance,* a corporação ganha reconhecimento diante de suas práticas, as quais seguirão também uma política de ética que agrega valor ao negócio e traz confiança perante os investidores já existentes e até mesmo a novas possibilidades de mercado. O *compliance* "[...] tem sido objeto de muitos debates atualmente, por tratar-se de um sistema de autocontrole recentemente introduzido no ordenamento jurídico brasileiro, pelas Leis 12.846/13 e 12683/2012, em razão de uma tendência mundial de levar as companhias a adotar programas eficientes de autocontrole de conduta" (SANTOS; TORRES; RODRIGUES, 2015, p. 3).



Saiba mais

Toda ação empregada dentro de uma empresa visa à geração de lucro. Dessa forma, salientamos que a empresa, além de adotar a política de *compliance,* deve também analisar os custos para tal ação. Quando isso ocorre, é comum que seja citada a teoria dos custos de transação, a qual traremos aqui apenas uma breve menção.

Conforme Ribeiro e Galeski Junior (2009), a teoria dos custos de transação foi alavancada por Williamson, pensador enquadrado na Teoria Neoinstitucionalista da Análise Econômica do Direito, o qual criticou a propalada perfeição do mercado, aventando que sempre existem custos nas relações de mercado e que estes influenciam na interação entre os agentes e nas condições de negociação, ou seja, no preço.

Entendendo o *Sarbanes-Oxley Act*

É importante que possamos compreender alguns assuntos que estão, de certa forma, relacionados aos marcos regulatórios da governança de TI. Estes marcos estão ligados também a questão do controle interno das organizações empresariais. Estamos falando, a princípio, da lei *Sarbanes-Oxley Act* (SOX). Sarbanes e Oxley são os nomes de dois senadores norte-americanos responsáveis pela criação da lei.



Figura 1. Os políticos Michel Oxcley e Paul Sarbanes.
Fonte: Wikimedia Commons (2015).

De acordo com Fernandes e Abreu (2012, p. 28), os motivadores do SOX (SARBANES; OXLEY, 2002), como é conhecido no mundo dos negócios, foram os escândalos financeiros acontecidos em companhias abertas nos Estados Unidos, como a Enron e outras, que minaram a confiança dos investidores no mercado de capital americano (em especial dos que investiam em ações dessas companhias nas bolsas de valores). Os autores complementam as informações mencionadas anteriormente esclarecendo que "[...] a bolsa de valores é o principal meio de investimento da maioria das famílias norte-americanas. Portanto, manter a credibilidade do 'sistema' é vital para os legisladores americanos e para os responsáveis pela condução econômica dos Estados Unidos" (FERNANDES; ABREU, 2012).

O objetivo principal da lei é fornecer proteção aos investidores de capitais americanos contra possíveis fraudes contábeis e financeiras de outras companhias. Além disso, a definição de penalidades aos possíveis crimes que podem ser relacionados ao contexto tem como ponto principal o controle interno da empresa e seus respectivos relatórios, que expõem suas atividades financeiras de maneira concisa e clara.

Ainda sob o ponto de vista de Fernandes e Abreu (2012, p. 28), para definir regras para os auditores independentes a respeito da lei, foi criado o *Public Company Accounting Oversight Board*, que é uma organização não governamental dedicada a criar normas a partir da lei.

O SOX é composto pelos seguintes títulos:

- Título I: *Public Company Accounting Oversight Board* (PCAOB). É uma organização não governamental que deve registrar as auditorias e estabelecer os padrões de auditoria relativos aos controles financeiros das empresas abertas.
- Título II: *Auditor Independence*. Estabelece que os auditores sejam independentes e que haja rotatividade entre empresas de auditoria.
- Título III: *Corporate Responsibility*. Atribui as responsabilidades corporativas, em termos da formação de um comitê de auditoria, da sua composição e dos requisitos sobre o envio de relatórios à SEC e outros tipos de conduta requeridos dos CEOs, CFOs e demais diretores.
- Título IV: *Enhanced Financial Disclosures*. Determina novas regras para a elaboração e publicação de resultados financeiros, assim como requer que a administração mantenha um sistema de controle interno adequado.
- Título V: *Analyst Conflicts of Interest*. Estipula regras para que não haja conflitos de interesse na atuação de analistas de corretoras de valores ou de administração de fundos.
- Título VI: *Comission Resources and Authority*. Concebe regras para autorização de fundos para a SEC, assim como a autoridade da SEC para suspender, temporariamente ou não, empresas e profissionais de auditoria.
- Título VII: *Studies and Reports*. Aqui o SOX autoriza a SEC a efetuar estudos e relatórios relativos à consolidação de firmas de auditoria, agências de *rating* de risco, violações profissionais no âmbito do mercado de capitais, análises dos resultados das ações da SEC e estudos de bancos de investimentos.
- Título VIII: *Corporate and Criminal Fraud Accountability*. Instaura regras específicas e penalidades para a destruição de registros corporativos, assim como para a alteração de dados e falsificações.
- Título IX: *White-Collar Crime Penalty Enhancements*. Contém penalidades para crimes do colarinho branco.
- Título X: *Corporate Tax Returns*. Estabelece que o CEO deve, obrigatoriamente, assinar o Imposto de Renda da Pessoa Jurídica.
- Título XI: *Corporate Fraud Accountability*. Define a responsabilidade corporativa pela comunicação de informações financeiras de resultados fraudulentos.

Podemos notar que a lei em si traz conceitos sobre varias práticas que abrangem o contexto da governança não só de tecnologia da informação,

mas também da governança que envolve a corporação. Ela define diretrizes para que sejam realizadas auditorias dos mais variados tipos dentro de uma corporação. Além disso, define e delimita as obrigações e limitações de cada cargo dentro da empresa, principalmente os de alto escalão, que estão conectados à gestão de riscos e às operações mais importantes que regem uma organização empresarial.



Link

No link ou código a seguir, você pode acessar a Portaria do Tribunal de Contas da União (TCU) nº. 22, de 04 de janeiro de 2013 (BRASIL, 2013), sobre o comitê gestor de TI. Nele, você pode ter verificar as métricas que regem o funcionamento do Comitê Gestor de Tecnologia da Informação no Tribunal de Contas da União. É interessante que você leia essa portaria para compreender como funciona um departamento de TI em um órgão público de nosso país.



https://goo.gl/oBj2Rz

Referências

BANCO CENTRAL DO BRASIL. *Resolução n° 3380*. Brasília, DF, 2006. Disponível em: <http://www.bcb.gov.br/pre/normativos/res/2006/pdf/res_3380_v2_L.pdf>. Acesso em: 09 dez. 2017.

BANCO DO BRASIL. *Análise do Desempenho 2T07*: 7.1.4 Novo Acordo de Capitais – Basiléia II. Brasília, DF: BB, 2014. Disponível em: <http://www.bb.com.br/portalbb/page51,136,3442,0,0,1,0.bb?codigoNoticia=4813&codigoMenu=410&codigoRet=4119>. Acesso em: 09 dez. 2017.

BRASIL. Tribunal de Contas da União. *Portaria-TCU nº 22, de 4 de janeiro de 2013*. Brasília, DF: TCU, 2013. Disponível em: <http://www.tcu.gov.br/Consultas/Juris/Docs/judoc%5CPORTN%5C20130121%5CPRT2013-022.doc>. Acesso em: 27 out. 2017.

CANDELORO, A. P. P.; RIZZO, M. B. M.; PINHO, V. *Compliance 360º*: riscos, estratégias, conflitos e vaidades no mundo corporativo. São Paulo: Trevisan, 2012.

FERNANDES, A. A.; ABREU, V. F. *Implantando a governança de TI*: da estratégia à gestão de processos e serviços. 3. ed. Rio de Janeiro: Brasport, 2012.

GONÇALVES, J. A. P. Alinhando processos, estrutura e compliance à gestão estratégica. São Paulo: Atlas, 2012.

RIBEIRO, M. C. P.; DINIZ, P. D. F. Compliance e lei anticorrupção nas empresas. *Revista de Informação Legislativa*, Brasília, DF, ano 52, n. 205, p. 87-105, 2015. Disponível em: <https://www12.senado.leg.br/ril/edicoes/52/205/ril_v52_n205_p87.pdf>. Acesso em: 21 nov. 2017.

RIBEIRO, M. C. P.; GALESKI JUNIOR, I. *Teoria geral dos contratos*: contratos empresariais e análise econômica. Rio de Janeiro: Elsevier, 2009.

SANTOS, D. O.; TORRES, R. L.; RODRIGUES, M. L. B. A regulamentação do programa de compliance pelo direito brasileiro, como ferramenta capaz de auxiliar as empresas no cumprimento de sua função social. *Revista Percurso*, Curitiba, v. 2, n. 17, 2015. Disponível em: <http://revista.unicuritiba.edu.br/index.php/percurso/article/view/1787>. Acesso em: 21 nov. 2017.

SANTOS, L. C.; BARUQUE, L. B. *Governança em tecnologia da informação*. Rio de Janeiro: Fundação CECIERJ, 2010.

SARBANES, P.; OXLEY, M. G. Sarbanes-Oxley act of 2002. In: CONGRESS, 107., 2002, Washington, DC. *Report 107-601, 2nd. session*. Washington, DC: U.S. Government, 2002.

WIKIMEDIA COMMONS. *File*: SarbanesOxley.jpg. [S.l.], 2015. Disponível em: <https://commons.wikimedia.org/wiki/File:SarbanesOxley.jpg>. Acesso em: 09 dez. 2017.

Encerra aqui o trecho do livro disponibilizado para esta Unidade de Aprendizagem. Na Biblioteca Virtual da Instituição, você encontra a obra na íntegra.

Conteúdo:

SOLUÇÕES EDUCACIONAIS INTEGRADAS